

Projet de Fin d'Etudes

Pour l'obtention du diplôme

D'Ingénieur d'Etat

Génie des Réseaux et Télécommunications

Promotion 2025/2026

Architecture zero trust : réduction de la surface
d'attaque par une gestion d'identité et de privilège
basé sur le modèle IAM/PIM

Stage réalisé au sein de : CGI



Réalisé par M. Mohammed Sbihi

Soutenance le XX/XX/XXXX

Membres de jury :

M. ENNAJAH YOUSSEF
M. HRAOUI SAID
M. ALLA LHOSSAINE

Encadrante Société
Encadrant ENSAF
Enseignant ENSAF

Remerciements

Je tiens à exprimer ma profonde gratitude à tous ceux qui ont contribué à la réussite de ce projet de fin d'études et à l'élaboration de ce rapport.

Avant tout, je remercie Dieu le Tout-Puissant de m'avoir donné la force, la santé et la volonté nécessaires pour mener à bien ce projet. Sa bénédiction m'accompagne tout au long de ce parcours.

A mon encadrant au sein de CGI Fes, pour son accueil chaleureux, sa confiance accordée dans le cadre de ce projet Zero Trust, ainsi que ses conseils pratiques et son accompagnement tout au long du stage. Son expertise du terrain et sa vision opérationnelle ont été essentielles pour adapter la solution aux contraintes réelles de l'entreprise.

A mon encadrant académique, pour ses conseils éclairés, son suivi rigoureux et sa disponibilité continue. Ses orientations méthodologiques ont été déterminantes dans l'aboutissement de cette réalisation.

A l'équipe pédagogique du département Génie des Télécommunications et Réseaux (GTR), pour la qualité de la formation dispensée, qui m'a permis d'acquérir les compétences nécessaires à la conception et à l'implémentation de cette architecture de cybersécurité.

A mes collègues et camarades étudiants, pour les échanges constructifs, l'entraide et le partage d'idées qui ont contribué à l'avancement de ce travail.

A ma famille, pour son soutien indéfectible, sa patience et ses encouragements constants durant les nombreuses heures consacrées à ce projet.

Ce projet n'aurait pu aboutir sans cette convergence de compétences, de conseils et d'encouragements. Il témoigne de l'importance de la collaboration dans le domaine de la cybersécurité, où la mutualisation des connaissances est essentielle pour répondre aux défis sécuritaires actuels.

Resume

Ce projet de fin d'études traite la reduction de la surface d'attaque dans un contexte d'administration de systemes critiques, a travers une architecture Zero Trust integree. Le probleme principal identifie est l'existence d'accès privileges permanents, peu traces et insuffisamment correles au niveau de criticite des actifs.

La solution proposee combine cinq briques principales : **Authentik** pour la gestion des identites (IAM), **Tailscale ACL** pour le controle d'accès reseau, une **application web Flask avec PostgreSQL** pour la gouvernance des demandes, un **moteur Python Just-in-Time** pour l'approbation/revocation automatisees, et **Wazuh** pour l'observabilite et la tracabilite de securite.

Le flux cible impose qu'aucun accès privilege ne soit permanent : chaque elevation est demandee, justifiee, approuvee, limitee dans le temps (TTL) puis retiree automatiquement. Les scenarios de validation couvrent l'authentification forte, la demande JIT, l'activation ACL, l'accès SSH pendant la fenetre autorisee, puis le refus apres expiration.

Les resultats attendus montrent une amelioration significative de la posture de securite : suppression des accès permanents non justifies, tracabilite complete du cycle d'accès, et meilleure capacite d'audit et de conforme.

Mots-cles : Zero Trust, IAM, PIM, PAM, Authentik, Tailscale, JIT, ACL, Wazuh, cybersecurite.

Abstract

This final-year project addresses attack-surface reduction in a privileged-access context through an integrated Zero Trust architecture. The main issue identified in the initial environment is the presence of persistent privileged access, limited traceability, and weak correlation between access rights and asset criticality.

The proposed solution combines five main building blocks : **Authentik** for Identity and Access Management (IAM), **Tailscale ACL** for network-level authorization, a **Flask web application with PostgreSQL** for request lifecycle governance, a **Python Just-in-Time engine** for automated approval and revocation, and **Wazuh** for centralized monitoring and auditability.

The target workflow enforces a strict principle : no permanent privileged access. Every elevation request must be justified, approved, time-bounded (TTL), and automatically revoked. Validation scenarios cover strong authentication, JIT request creation, ACL activation, SSH access during authorized time windows, and automatic denial after expiration.

Expected outcomes include a stronger security posture, full end-to-end traceability of privileged access, and improved compliance evidence for audit processes.

Keywords : Zero Trust, IAM, PIM, PAM, Authentik, Tailscale, JIT, ACL, Wazuh, cybersecurity.

ملخص

يتناول مشروع نهاية الدراسة هذا تقليص مساحة الهجوم في سياق إدارة الأنظمة الحساسة، وذلك من خلال بنية تحتية متكاملة قائمة على مبدأ "انعدام الثقة" (Zero Trust). تكمن الإشكالية الرئيسية التي تم تحديدها في وجود صلاحيات وصول امتيازية دائمة، تفتقر إلى التتبع الدقيق ولا ترتبط بشكل كافٍ بمستوى حساسية الأصول الرقمية.

تعتمد الحلول المقترحة على دمج خمس ركائز أساسية: Authentik لإدارة الهويات، (IAM) و Tailscale ACL للتحكم في الوصول إلى الشبكة، وتطبيق ويب Flask مع قاعدة بيانات PostgreSQL لحوكمة الطلبات، ومحرك Python (Just-in-Time) للأتمتة والموافقة أو الإلغاء التلقائي، بالإضافة إلى Wazuh لضمان قابلية المراقبة والتتبع الأمني.

يفرض مسار العمل المستهدف عدم وجود أي وصول امتيازي دائم؛ حيث يتم طلب كل رفع للصلاحيات وتبريره والموافقة عليه، مع تقييده بفترة زمنية محددة (TTL) ثم سحبه تلقائياً. تشمل سيناريوهات التحقق: المصادقة القوية، طلب الوصول الآني، (JIT) تفعيل الـ ACL، والوصول عبر بروتوكول SSH خلال النافذة الزمنية المسموح بها، متبوعاً برفض الوصول فور انتهاء الصلاحية.

تُظهر النتائج المتوقعة تحسناً ملحوظاً في الوضع الأمني من خلال: إلغاء الوصول الدائم غير المبرر، التتبع الكامل لدورة حياة الوصول، وتعزيز القدرة على التدقيق والامتثال للمعايير الأمنية.

الكلمات المفتاحية: Zero، Trust، IAM، PIM، PAM، Authentik، Tailscale، JIT، ACL، Wazuh، الأمن السيبراني.

Liste des abreviations

ACL	Access Control List
API	Application Programming Interface
CVE	Common Vulnerabilities and Exposures
CVSS	Common Vulnerability Scoring System
IAM	Identity and Access Management
JIT	Just-in-Time
MFA	Multi-Factor Authentication
OIDC	OpenID Connect
PAM	Privileged Access Management
PFE	Projet de Fin d'Etudes
PIM	Privileged Identity Management
RBAC	Role-Based Access Control
SIEM	Security Information and Event Management
SOC	Security Operations Center
SSO	Single Sign-On
TTL	Time To Live

Table des matières

Remerciements	I
Resume	II
Abstract	III
	IV
Liste des abreviations	V
1 Representation CGI	2
1.1 Presentation de l'organisme CGI	2
1.2 Activites et taches professionnelles exercees	5
1.3 Conclusion du chapitre	8
2 Contexte et problematique	10
2.1 Introduction du chapitre	10
2.2 Contexte entreprise et projet VIC	10
2.3 Probleme de securite identifie	10
2.4 Motivation Zero Trust	11
2.5 Conclusion du chapitre	11
3 Objectifs, perimetre et methodologie	13
3.1 Introduction du chapitre	13
3.2 Objectif general du PFE	13
3.3 Perimetre technique	13
3.4 Approche methodologique	14
3.5 Conclusion du chapitre	14
4 Architecture Zero Trust globale	16
4.1 Introduction du chapitre	16
4.2 Vue d'ensemble	16
4.3 Architecture reseau de deploiement	16
4.4 Alternatives et choix	17

4.5	Flux de securite cible	17
4.6	Conclusion du chapitre	18
5	Implementation par composant	20
5.1	Introduction du chapitre	20
5.2	Authentik (IAM)	20
5.3	Tailscale ACL (controle reseau)	23
5.4	Application Flask et base PostgreSQL	26
5.5	Moteur JIT Python (ACL_work)	30
5.6	Wazuh et observabilite	31
5.7	Conclusion du chapitre	33
6	Scenarios de test et validation	35
6.1	Introduction du chapitre	35
6.2	Strategie de test	35
6.3	Contexte d'execution des tests	35
6.4	Cas de test IAM/PIM/PAM	36
6.5	Resultats de validation	40
6.6	Conclusion du chapitre	41
7	Resultats, metriques et discussion	43
7.1	Introduction du chapitre	43
7.2	Indicateurs avant/apres	43
7.3	Analyse des gains	44
7.4	Conclusion du chapitre	44
8	Limites et perspectives	46
8.1	Introduction du chapitre	46
8.2	Limites techniques actuelles	46
8.3	Perspectives court terme	46
8.4	Perspectives long terme	46
8.5	Conclusion du chapitre	47
9	Conclusion generale	49
9.1	Introduction du chapitre	49
9.2	Conclusion du chapitre	49

Table des figures

1.1	CGI en chiffres : presentation globale de l'entreprise et de ses capacites.	2
1.2	Evolution de l'identite visuelle et des logos de CGI au cours des quatre decennies.	3
1.3	Organigramme de la societe CGI : structure de direction et gouvernance.	3
1.4	Presence geographique de CGI au Maroc : sites de Casablanca, Rabat et Fes.	4
5.1	Etape 1: saisie de l'email utilisateur dans le flux de connexion Tailscale.	20
5.2	Etape 2: redirection vers Authentik pour la verification d'identite (SSO IAM).	21
5.3	Etape 3: retour vers Tailscale apres authentification validee par Authentik.	21
5.4	Page de connexion IAM de l'application, point d'entree du controle d'identite.	22
5.5	Configuration de l'application dans Authentik (provider, integration et parametres de federation).	22
5.6	Groupes utilises pour la politique d'accès et l'application des droits par profil.	23
5.7	Etat ACL avant approbation : politique restrictive, sans autorisation explicite pour l'utilisateur cible.	24
5.8	Etat ACL apres approbation : regle d'accès temporaire ajoutée pour permettre la connexion.	25
5.9	Vue des utilisateurs Tailscale, utilisee pour verifier les identites effectives dans le tailnet.	26
5.10	Dashboard utilisateur (user side) : consultation de l'etat des acces et lancement d'une demande JIT.	27
5.11	Dashboard administrateur (admin side) : supervision globale des demandes et des actions de gouvernance.	27
5.12	Vue profil admin : verification des attributs d'identite et des permissions associees au role administrateur.	28
5.13	Interface de traitement des demandes d'accès cote admin (liste des requetes et statut).	28

5.14	Action d'approbation d'une demande par l'administrateur, declenchant l'activation ACL temporaire.	29
5.15	Etat de la demande apres approbation vu depuis l'interface administrateur.	29
5.16	Etat cote utilisateur apres validation admin : acces marque comme approuve avec fenetre temporelle active.	30
5.17	Fonction de revocation d'accès dans le moteur Python : suppression des regles ACL SSH/Grant et gestion du rollback en cas d'echec API.	31
5.18	Code de journalisation SSH.	32
5.19	Preuve de centralisation Wazuh : traces de commandes SSH executees sur la machine cible avec contexte utilisateur.	33
6.1	Preuve TC-01: ecran de connexion IAM avant emission d'une session valide.	36
6.2	Preuve TC-03: action d'approbation executee par l'administrateur.	37
6.3	Preuve TC-03: regle ACL active apres approbation de la demande.	38
6.4	Preuve TC-04 (avant approbation) : tentative SSH refusee car aucun droit temporaire n'est encore actif.	39
6.5	Preuve TC-04 (apres approbation) : tentative SSH acceptee pendant la fenetre d'accès JIT.	39
6.6	Preuve TC-06: evenements Wazuh issus des commandes SSH journalisees sur la machine cible.	40

Liste des tableaux

7.1	Comparatif des indicateurs de sécurité (Avant vs Après)	43
-----	---	----

Chapitre 1 : Representation CGI

1 Representation CGI

1.1 Presentation de l'organisme CGI

1.1.1 Presentation generale

CGI (*Conseillers en gestion et informatique*) est l'une des rares entreprises possédant l'envergure, la portée et les capacités pour répondre aux besoins des clients en matière de transformation numérique. Elle offre des services-conseils complets et innovants en TI et en management grâce à un modèle d'affaires axé sur la proximité avec les clients.

Elle travaille de concert avec eux et met à profit ses capacités mondiales pour définir, élaborer, mettre en œuvre et exécuter les stratégies et solutions requises pour satisfaire aux attentes des consommateurs et des citoyens.

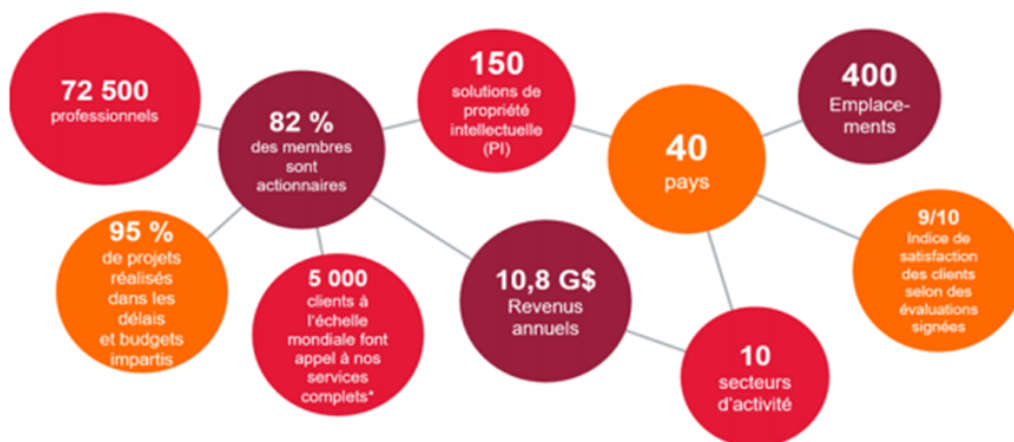


Fig. 1.1 : CGI en chiffres : présentation globale de l'entreprise et de ses capacités.

CGI tire parti de sa présence mondiale grâce à ses 400 emplacements répartis dans 40 pays et qui regroupent 72 500 membres, dont la majorité sont des actionnaires de CGI. Ses professionnels agissent à titre de partenaires de confiance pour plus de 5 000 clients à l'échelle mondiale.

Forts de plus de quatre décennies de croissance soutenue, elle offre une expertise spécialisée dans 10 secteurs d'activité et bonifie son offre de services grâce à un portefeuille de plus de 150 solutions fondées sur la propriété intellectuelle. Sa détermination à surpasser les attentes de ses clients se traduit par une note globale de satisfaction des clients de 9 sur 10. Son bilan inégalé de 95 % de projets réalisés selon les échéances et budgets prévus témoigne de son engagement envers l'excellence opérationnelle.

1.1.2 Historique

CGI a été fondée en 1976 par deux entrepreneurs de 26 ans, Serge Godin et André Imbeau. Ils ont démarré l'entreprise dans le sous-sol de la résidence de Serge dans la ville de Québec avec un seul client, un téléphone et beaucoup d'ambition.

Aujourd'hui, plus de 72 500 professionnels travaillent dans le monde entier. La société s'étant mondialisée, elle est maintenant connue simplement sous le nom de CGI. Ensemble, les professionnels de CGI ont bâti l'une des plus importantes entreprises de services en technologies de l'information et en gestion des processus d'affaires au monde.



Fig. 1.2 : Evolution de l'identité visuelle et des logos de CGI au cours des quatre décennies.

1.1.3 Organigramme de l'entreprise



Fig. 1.3 : Organigramme de la société CGI : structure de direction et gouvernance.

1.1.4 CGI Maroc

CGI figure parmi les plus importants fournisseurs de services en technologies de l'information au monde. Au Maroc, où travaillent 700 de ses professionnels, elle offre

des services complets en TI, dont des services-conseils en management ainsi que des services d'integration de systemes, en gestion des processus d'affaires et d'impartition.

CGI dispose de plusieurs centres techniques et fonctionnels au Maroc. L'equipe CGI au Maroc offre actuellement des services a plusieurs clients actifs formes de grands noms francais pour qui l'entreprise realise une cinquantaine de projets.

Comme le montre l'illustration, CGI est presente sur le territoire marocain dans Casa (Casablanca) et Rabat depuis le demarrage. Depuis le 21 decembre 2016, CGI est desormais presente sur Fes dans le parc FESSHORE dans le cadre de l'extension des locaux CGI au Maroc.



Fig. 1.4 : Presence geographique de CGI au Maroc : sites de Casablanca, Rabat et Fes.

1.1.5 GTO (Global Technology Operations)

Global Technology Operations (GTO) regroupe l'ensemble des activites techniques et infrastructures de CGI France. Cette unite operationnelle est organisee selon les principes suivants :

- Une organisation operationnelle perenne dans l'ere digitale.
- Offreurs, Project/Delivery Managers, Architectes, Batisseurs Experts et Industriels.
- Une combinaison equilibree des forces pour realiser la proposition de valeur GTO.
- Des equipes pluridisciplinaires transverses, adressant tout le cycle de vie des projets et des services.
- Des equipes constituees en fonction des enjeux a adresser, tant externes qu'interne.

- Une approche par proposition de valeur decloisonnant les technologies, perenne dans un monde digital.
- Une organisation construite pour offrir une evolution de carriere a tous les metiers de GTO.

1.1.6 Services proposes par CGI

CGI offre un eventail complet de services, de solutions et d'expertise pour acclereler la transformation des activites de ses clients :

- **Services-conseils strategiques** : Strategie informatique et d'affaires, architecture d'entreprise, refonte des processus, gestion du changement et mesure de la performance.
- **Integration de systemes** : Architecture de systemes, developpement de systemes et mise en oeuvre de solutions technologiques et d'affaires.
- **Developpement et gestion des applications** : Conception, developpement, mise en oeuvre, maintenance et amelioration des applications informatiques.
- **Services d'infrastructure** : Gestion des infrastructures completes selon les besoins et priorites de chaque client.
- **Gestion des processus d'affaires** : Gestion des processus d'arriere-guichet afin d'optimiser les operations.
- **Solutions exclusives** : Portefeuille de plus de 100 solutions essentielles aux organisations.

1.2 Activites et taches professionnelles exercees

1.2.1 Integration et formations initiales

Des notre integration a CGI, nous avons ete invites a suivre des formations e-learning obligatoires couvrant la sensibilisation a la securite informatique, le cadre de gestion du partenariat client, le code d'ethique et de conduite professionnelle, et la conformite RGPD. Ces formations ont facilite notre integration au sein de CGI et nous ont permis de comprendre les valeurs et pratiques de l'entreprise.

1.2.2 Equipes techniques VIC et SMI N2

Durant le stage, en parallele a la conduite de notre projet de fin d'etude, nous avons eu la chance d'etre affectes a deux equipes techniques strategiques : **l'equipe VIC** et **l'equipe SMI N2**.

1.2.2.1 Equipe VIC (Vulnerability, Inventory, Conformity)

L'équipe VIC gère un parc hétérogène composé de serveurs Linux et Windows, d'applications web, de bases de données et de services d'infrastructure. Le cœur de son métier repose sur l'identification, la priorisation et la remédiation des vulnérabilités.

Dans ce contexte, VIC couvre trois dimensions complémentaires : **Vulnerability**, **Inventory** et **Conformity**. Cette approche permet de relier l'inventaire des actifs, la conformité de l'infrastructure et le traitement des risques de sécurité.

La mission de l'équipe s'articule autour de six axes de travail :

- **Tache 1 – Analyse et priorisation des vulnérabilités** : évaluation de la criticité, définition des actions de remédiation et suivi de leur exécution.
- **Tache 2 – Qualification des vulnérabilités** : qualification des vulnérabilités système et applicatives, puis évaluation des risques associés.
- **Tache 3 – Suivi du cycle de vie** : pilotage de bout en bout des vulnérabilités, de la détection jusqu'à la vérification post-correction.
- **Tache 4 – Gestion de l'obsolescence** : traitement des serveurs, VM et OS obsolètes (mise à jour, migration ou décommissionnement) avec appui de la CMDB Flexera.
- **Tache 5 – Collaboration transverse** : coordination avec les équipes systèmes et réseaux pour corriger les failles et réduire la surface d'attaque.
- **Tache 6 – Gestion opérationnelle des tickets** : suivi et qualification des tickets de vulnérabilités et d'incidents via OTRS et BMC, ainsi que gestion des exceptions et des risques résiduels via Archer.

1.2.2.2 Equipe SMI N2 (Support Microsoft Infrastructure - Niveau 2)

L'équipe SMI N2 est organisée selon une hiérarchie de support technique :

- **SMI Build** : Responsable du build et de la construction des serveurs, environnements et infrastructure.
- **SMI Run** : Responsable de la gestion opérationnelle quotidienne, de la supervision et de la maintenance des serveurs en production.
- **SMI N2 Technique** : Niveau de support avancé pour la résolution des incidents complexes et le support du N1.

Notre role principal au sein de ces equipes a ete de porter assistance aux utilisateurs des projets des clients de CGI, notamment par la resolution de tickets d'incident, la participation aux operations de surveillance, la coordination entre les equipes SMI Build et SMI Run, et le diagnostic des problemes techniques.

1.2.3 Tâches réalisées et contributions

1.2.3.1 Support Technique de Niveau 2 (N2)

Ma contribution principale a consisté en la prise en charge d'incidents complexes escaladés par le premier niveau. Contrairement au support basique, mon rôle en tant qu'administrateur N2 au sein de l'équipe *Windows Virtualization* implique une analyse approfondie des couches systèmes et applicatives :

- **Diagnostic et Troubleshooting** : Identification des causes racines (*Root Cause Analysis*) par l'analyse des journaux d'événements (*Event Viewer*), l'étude des dumps mémoires et l'utilisation d'outils de diagnostic réseau.
- **Gestion des environnements virtualisés** : Administration courante via **VMware vSphere** ou **Hyper-V** (gestion des snapshots, extension de disques à chaud, modification des ressources vCPU/RAM).
- **Administration Active Directory** : Gestion des droits d'accès, dépannage des problèmes d'authentification et application de stratégies de groupe (GPO) pour sécuriser le parc.
- **Exemple concret** : Résolution d'une corruption de base de données d'un serveur de profils itinérants, nécessitant une restauration granulaire et une reconfiguration des droits NTFS.

1.2.3.2 Supervision et Maintien en Condition Opérationnelle (MCO)

En parallèle du traitement des tickets, j'ai participé activement à la pérennité et à la performance de l'infrastructure de production :

- **Monitoring proactif** : Surveillance des métriques de performance (CPU, Latence E/S, RAM) via les outils de supervision pour anticiper les saturations avant qu'elles n'impactent les utilisateurs finaux.
- **Gestion des changements (Change Management)** : Application de correctifs de sécurité et mise à jour des systèmes dans le respect des fenêtres de maintenance.

1.3 Conclusion du chapitre

L'expérience acquise au sein de CGI, particulièrement au travers des équipes VIC et SMI N2, a fourni une base solide de compréhension des opérations techniques, de la gestion des incidents et des bonnes pratiques de l'industrie. Ces compétences opérationnelles ont directement enrichi la conception et la mise en oeuvre du projet de fin d'étude sur l'architecture Zero Trust.